Publication LinkedIn

Un agent peut préparer une action pertinente sans avoir l'autorité de l'exécuter.

Cette distinction est au cœur de mon travail sur Swarm, un moteur d'orchestration multi-agents à contrôle déterministe.

L'objectif est de relier chaque action à une identité, un mandat, un contenu approuvé et un résultat vérifiable. Les agents raisonnent et proposent ; les opérations contrôlées par le moteur restent soumises aux règles et validations applicables.

Les standards apportent déjà des réponses complémentaires : ISO pour le management et les risques, OWASP pour les risques agentiques et les contrôles à l'exécution, NIST pour les architectures et catalogues de contrôles, SPIFFE pour l'identité des processus.

L'Agent Control Standard de l'OWASP décrit lui-même une couche déterministe. La question devient celle de son application dans un processus complet.

Une approbation reste-t-elle valable après un changement de bénéficiaire ? Une révocation empêche-t-elle l'action avant son engagement ? Après une réponse perdue, la reprise évite-t-elle un second effet ? L'agent peut-il contourner le contrôle avec un autre outil ?

Ces questions demandent des preuves sur une version, une configuration et un périmètre précis.

Je distingue trois responsabilités : vérifier les règles, protéger les clés et imposer les points de passage vers les effets réels. Leur séparation doit résister aux moyens techniques accessibles à l'agent.

Au 25 octobre 2026, le noyau Biba Rust de Swarm est consigné comme livré localement pour les actions de confiance simulées, avec mandats, accords exacts et mécanismes de reprise. Le raccord global de l'identité et de la mémoire reste à qualifier ; le confinement général prévu par AC-02 n'est pas démarré.

Swarm ne revendique aucune certification de sécurité agentique. Je propose de prolonger sa matrice de contrôles par un profil d'assurance : une exigence explicite, un test nommé, une preuve et une limite déclarée pour chaque garantie recherchée.

Pour les actions critiques, je défends une autonomie d'engagement conditionnée à ces garanties et aux validations requises par le contexte.

Quelles preuves exigez-vous avant de laisser un agent engager une action irréversible ?

Fabrice Pizzi

#Swarm #AgenticAI #AISecurity #Cybersecurity

Swarm et la sécurité des agents autonomes

La sécurité d'un système agentique demande de vérifier ce que ses agents peuvent réellement faire, avec quelle autorité et dans quelles conditions. C'est le sujet que j'explore avec Swarm, un moteur d'orchestration multi-agents à contrôle déterministe.

Mon objectif est de relier chaque action à une identité, un mandat, un contenu approuvé et un résultat vérifiable. Cette continuité doit être examinée jusqu'à l'engagement de l'effet, puis pendant les reprises après incident. Les garanties se démontrent sur une version, une configuration et un périmètre identifiés.

Le passage du raisonnement à l'action

Un modèle peut analyser une situation, proposer un plan et choisir des outils. Lorsqu'il accède à des fichiers, des services ou des commandes, une erreur de raisonnement peut entraîner une modification durable. Une consigne erronée conservée dans une mémoire peut ensuite influencer une autre instance.

Swarm organise objectifs, tâches, dépendances, responsabilités, contrôles et preuves. Son architecture sépare les propositions des agents et la vérification des transitions par le moteur. Le contrôle humain intervient selon la politique applicable ; une revue IA favorable ne remplace pas une décision humaine obligatoire.

Cette architecture doit aussi préciser ses frontières. Contrôler une transition Swarm ne prouve pas que tous les accès de l'agent aux systèmes externes sont interceptés. Un outil disposant d'un chemin direct vers une ressource sensible peut conserver un pouvoir que le processus d'orchestration entendait limiter.

Des standards complémentaires

Les références de sécurité apportent des réponses à des niveaux différents. ISO/IEC 27001 et 42001 définissent des exigences de management pour la sécurité de l'information et l'IA. ISO/IEC 23894 fournit des recommandations de gestion des risques IA. Leur portée concerne notamment l'organisation qui développe ou exploite le système. [1–3]

Le Top 10 agentique de l'OWASP aide à identifier les risques : détournement d'objectif, abus de privilèges, contamination de mémoire ou défaillances en cascade. L'Agent Control Standard décrit les points d'interception et les échanges nécessaires au contrôle à l'exécution. Son dépôt décrit déjà une couche déterministe, avec un recours optionnel à un LLM. [4–5]

Le NIST apporte l'architecture Zero Trust et des catalogues de contrôles. SPIFFE spécifie des identités vérifiables pour les processus et services. L'authentification doit ensuite être reliée aux droits sur les ressources et aux contraintes de l'opération. OWASP ASVS fournit, de son côté, des exigences de vérification pour les applications et services web. [6–9]

Je situe Swarm dans cet ensemble. Son apport recherché est de relier ces préoccupations au déroulement concret d'un travail multi-agents : délégation, validation, changement de contexte, engagement et reprise. Une compatibilité avec un standard doit être définie et testée avant d'être annoncée.

Les règles les clés et les points de passage

Le gardien des règles vérifie l'identité, le mandat, la politique courante et les validations nécessaires. Une analyse produite par un modèle peut éclairer cette décision ; elle ne doit pas créer seule de nouveaux droits.

Le gardien des clés protège les moyens techniques d'agir. Un agent qui prépare une opération sensible doit recevoir uniquement les capacités nécessaires à son rôle. Les secrets critiques doivent rester détenus par des composants dont les accès sont contrôlés.

Les garde-barrières appliquent les décisions aux connecteurs, aux processus, aux fichiers et au réseau concernés. Ils doivent empêcher les chemins alternatifs accessibles à l'agent de contourner un refus.

Ces fonctions demandent des frontières techniques vérifiées. Trois modules partageant les mêmes privilèges et pouvant modifier leurs clés ou politiques respectives ne démontrent pas une séparation indépendante. De même, observer une opération après son exécution apporte une trace, mais ne démontre pas qu'elle pouvait être empêchée.

Une approbation doit suivre le contenu exact

Prenons une facture et une proposition de règlement. Le montant, la devise et le bénéficiaire sont approuvés. Un message arrive ensuite avec de nouvelles coordonnées bancaires.

L'opération modifiée doit repasser par les contrôles applicables. L'approbation précédente portait sur un autre contenu. Le service qui engage l'effet doit vérifier une dernière fois l'action exacte, le mandat courant et les validations requises au point de sérialisation prévu par son contrat.

Une panne introduit une autre difficulté. Si le service a exécuté l'opération mais que sa réponse est perdue, une nouvelle tentative peut produire un doublon. La reprise doit conserver l'intention durable, distinguer les issues connues ou inconnues et réconcilier l'état avant une répétition susceptible de créer un second effet.

Un connecteur simulé permet d'éprouver ces mécanismes. Leur application à un service réel exige de vérifier son propre contrat d'idempotence, ses réponses, ses erreurs et ses moyens de réconciliation.

Une mémoire ne crée aucune autorité

La mémoire rend une expérience réutilisable. Elle doit aussi conserver sa provenance, sa version, ses conditions d'usage et les droits de transmission associés. Une information utile peut devenir dangereuse si elle est reprise hors de son contexte ou transmise au mauvais destinataire.

Une signature peut établir une origine et une intégrité sous ses hypothèses de confiance. Elle ne démontre pas la vérité du contenu. Le modèle Biba encadre les flux d'intégrité ; il ne fournit pas une compréhension sémantique générale des instructions malveillantes et ne garantit pas la confidentialité.

Le retrait d'une mémoire peut empêcher de nouveaux usages contrôlés. Il ne supprime pas rétroactivement les informations déjà transmises à une conversation ou à un fournisseur. La reprise doit tenir compte du contexte effectivement reçu.

Les garanties actuelles de Swarm

Au 25 octobre 2026, le plan BIBA-RUST consigne la livraison locale du noyau des actions de confiance : moniteur I0–I3, identités locales, mandats, accords exacts, deux effets simulés, idempotence et réconciliation, avec des parcours CLI, API et web.

Cette portée reste explicite. Les effets sont simulés ; le noyau ne soumet pas toutes les missions à Biba et ne constitue pas un confinement Linux. Les contrats d'identité et de mémoire comportent encore des raccordements à qualifier. Le plan AC-02 de confinement général et de médiation réseau et secrets est enregistré, sans démarrage.

Swarm possède également une matrice reliant douze contrôles NIST sélectionnés à des preuves contextuelles locales. Ces correspondances conservent leurs écarts. Elles ne constituent ni un score de conformité, ni une certification, ni une évaluation indépendante du système complet.

Un profil d’assurance testable

Je propose de prolonger cette matrice par un profil d’assurance de l’exécution agentique. Il permettrait de décrire huit exigences : identité et délégation, intégrité et admission, mémoire gouvernée, contrôle au point d’engagement, capacités et accès, effets et reprise, validation humaine, preuves et qualification.

Pour chaque exigence, l’évaluation doit préciser le périmètre, la référence externe, le mécanisme, un test nommé, les preuves, les limites et le responsable. Les scénarios doivent comprendre un témoin valide, les refus attendus et la reprise après incident.

On doit notamment pouvoir montrer qu’un changement de contenu invalide l’accord précédent, qu’une révocation bloque les nouvelles opérations concernées, qu’une réponse perdue ne duplique pas l’effet et qu’une panne du contrôle ne libère pas l’action sensible. Les voies de contournement doivent être exercées dans le modèle de menace déclaré.

Ce profil reste une proposition documentaire. Il ne crée aucune conformité présumée. Une unité réussie, une simulation, une intégration réelle et une qualification indépendante apportent des preuves différentes.

Pour les actions critiques, je défends une autonomie d’engagement conditionnée aux garanties et aux validations requises par le contexte. Cette position relève de l’ingénierie ; elle ne prétend pas décrire une interdiction réglementaire générale.

Avec Swarm, je cherche à rendre cette exigence concrète : pouvoir examiner qui a autorisé une action, sur quel contenu, sous quelles règles et avec quel effet réellement observé.

Fabrice Pizzi

#Swarm #AgenticAI #AISecurity #Cybersecurity

Références publiques

1. ISO IEC 27001 Systèmes de management de la sécurité de l'information
2. ISO IEC 42001 Systèmes de management de l'IA
3. ISO IEC 23894 Gestion des risques IA
4. OWASP Top 10 for Agentic Applications 2026
5. OWASP Agent Control Standard et dépôt de spécification
6. NIST SP 800 207 Zero Trust Architecture
7. NIST SP 800 53 Rev 5 Catalogue de contrôles
8. SPIFFE Concepts et identités de workloads
9. OWASP Application Security Verification Standard

La documentation du dépôt Swarm conserve les limites d'implémentation et les liens vers les preuves locales. Les sources publiques présentent leurs propres mécanismes ; elles n'établissent aucune certification de Swarm.